

**LAPORAN AKHIR PROJEK PRAKTIKUM KEAMANAN SIBER
SOC ANALYST SIMULATION: MAN-IN-THE-MIDDLE HUNTER
SIMULASI SNIFFING & ARP SPOOFING SERTA INCIDENT RESPONSE
LAYER 2**

KELOMPOK 9

Anggota Kelompok :

Dimas Dzikra Pratama

(J0404231126)

Muhammad Aqil Fazli Yulianto

(J0404231147)



**PROGRAM STUDI TEKNOLOGI REKAYASA KOMPUTER
SEKOLAH VOKASI IPB UNIVERSITY**

2026

BAB I: RINGKASAN EKSEKUTIF

2.1 Latar Belakang Infrastruktur

Dalam arsitektur jaringan lokal tradisional, komunikasi pada Data Link Layer (Layer 2) sangat bergantung pada Address Resolution Protocol (ARP) untuk memetakan alamat IP logis ke alamat MAC fisik. Namun, protokol ARP bawaan dirancang tanpa adanya mekanisme otentikasi (kepercayaan implisit). Kelompok 9 membangun sebuah lingkungan simulasi Security Operations Center (SOC) yang merepresentasikan arsitektur jaringan perusahaan fungsional untuk menguji kerentanan ini.

Infrastruktur yang dibangun berbasis Linux Bridge (br0 pada VM-Switch) yang mengisolasi dua segmen jaringan menggunakan Virtual Local Area Network (VLAN), yaitu VLAN-Victim (VLAN 10) dan VLAN-Web/Server (VLAN 20). Guna menyediakan visibilitas penuh bagi pemantauan SOC, kami mengimplementasikan teknik Port Mirroring atau Switched Port Analyzer (SPAN Port) pada interface internal bridge. Seluruh lalu lintas data mentah (raw traffic) duplikat dialirkan secara langsung ke interface monitoring enp0s10 milik mesin Security Onion 2.3 yang bertindak sebagai platform SIEM pusat.

1.2 Jenis Insiden yang Disimulasikan

Jenis insiden yang disimulasikan dalam proyek ini dikategorikan berdasarkan NIST sebagai Unauthorized Access via Man-in-the-Middle (MITM) Attack. Penyerang yang berada di dalam segmen jaringan lokal meluncurkan serangan ARP Spoofing (ARP Poisoning) menggunakan tools Kali Linux.

Tujuan dari serangan ini adalah meracuni ARP cache milik mesin korban (Victim PC) dan Gateway/Server, sehingga memaksa jalur komunikasi Layer 2 berbelok melewati mesin penyerang terlebih dahulu sebelum diteruskan ke tujuan asli. Setelah memposisikan diri di tengah rute jaringan, penyerang melakukan packet sniffing (penyadapan paket) secara aktif untuk mengeksploitasi protokol transmisi data yang bersifat tidak terenkripsi (plaintext), dalam skenario ini adalah layanan File Transfer Protocol (FTP) yang berjalan pada port 21. Insiden ini mensimulasikan pencurian kredensial sensitif (password leaking) serta eksfiltrasi dokumen internal perusahaan.

1.3 Ringkasan Hasil Deteksi dan Respon

Melalui integrasi sensor keamanan L2, visibilitas SOC berhasil dipertahankan secara optimal. Eksploitasi ARP Spoofing memicu anomali pergantian alamat MAC yang sangat cepat untuk satu identitas IP tunggal pada jaringan. Aktivitas mencurigakan ini langsung memicu alert critical dari modul Arpwatch yang terintegrasi pada sistem monitoring, memunculkan notifikasi "Flip-Flop" pada dasbor pemantau.

Secara simultan, mesin Security Onion menangkap paket data mentah dari jalur SPAN Port. Melalui analisis mendalam (Deep Packet Inspection), tim SOC berhasil mengidentifikasi kebocoran teks kredensial otentikasi serta nama file dokumen yang dieksfiltrasi oleh penyerang. Insiden berhasil ditangani dalam waktu kurang dari 15 menit melalui tindakan respon terstruktur: penahanan (containment) menggunakan aturan firewall Layer 2 berbasis Etables untuk memblokir MAC address penyerang di level switch, diikuti pemulihan tabel ARP ke kondisi statis terlindungi.

BAB II: FASE DETEKSI & ANALISIS (DETECTION & ANALYSIS)

2.1 Metode Deteksi

Sesuai dengan panduan penanganan insiden NIST SP 800-61 Rev. 2, fase deteksi dilakukan melalui dua mekanisme pertahanan:

1. Mekanisme Signature & Anomaly Detection (Arpwatch/IDS): Sensor Arpwatch bekerja secara aktif memantau aktivitas request dan reply paket ARP pada interface br0. Ketika penyerang mengirimkan paket gratuitous ARP reply palsu secara terus-menerus, Arpwatch mendeteksi bahwa alamat IP milik server (192.168.9.50) yang awalnya diasosiasikan dengan MAC Address fisik server asli tiba-tiba berubah menjadi terikat dengan MAC Address milik perangkat Kali Linux (08:00:27:63:60:05). Sistem langsung mencatat log anomali berstatus CRITICAL dengan tipe pesan changed hardware address atau flip-flop.
2. Mekanisme Network-based Visibility (SPAN Port): Karena VM-Switch telah dikonfigurasi untuk melakukan mirroring paket dari port Fa0/3 (Victim) dan Fa0/5 (Server) ke port Fa0/10 (Security Onion), semua paket data hasil pembelokan oleh penyerang tetap terduplikasi ke sistem SIEM. Dasbor Kibana menampilkan visualisasi grafik lonjakan paket ARP yang tidak wajar selama jendela waktu serangan berlangsung.

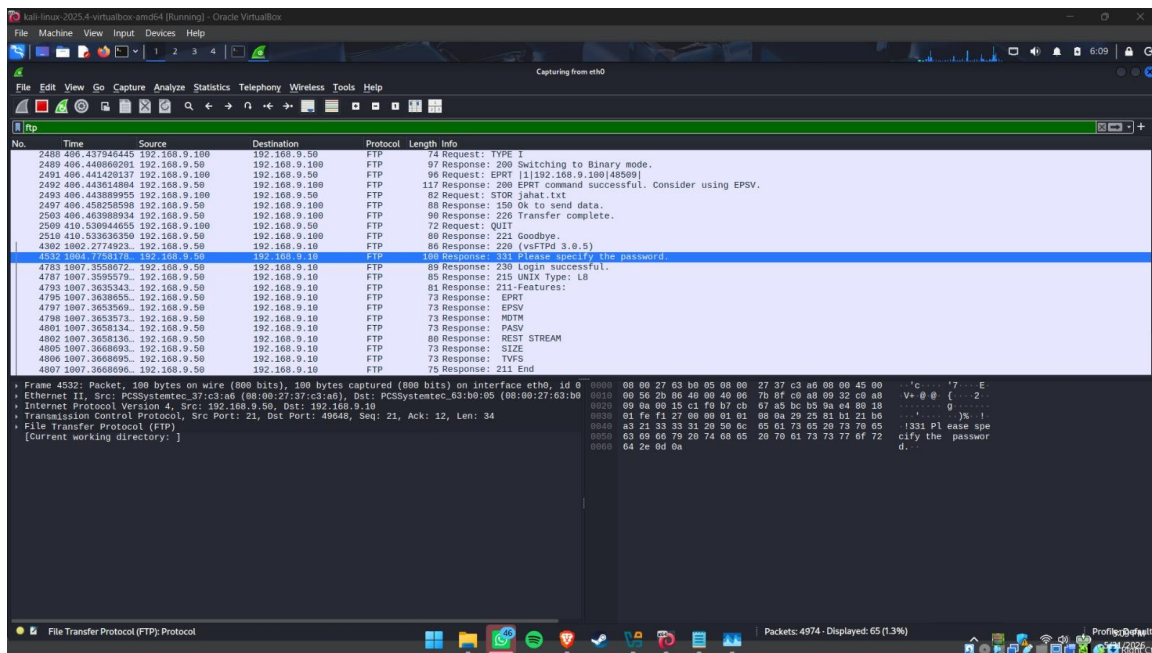
2.2 Analisis Log Jaringan

Analisis log dari Security Onion dan dasbor Kibana menunjukkan visualisasi data sebagai berikut:

- Identifikasi Frekuensi: Terjadi lonjakan paket ARP Reply (Opcode 2) sebanyak ratusan paket dalam rentang waktu kurang dari 2 detik. Pola transmisi secepat ini mengonfirmasi adanya penggunaan automated tools (seperti arpspoof atau Ettercap) oleh pihak penyerang, bukan aktivitas scanning atau koneksi manual yang dilakukan oleh pengguna normal.
- Korelasi Kejadian: Dasbor SIEM berhasil mengorelasikan waktu awal munculnya peringatan anomali fisik dari Arpwatch (Pukul 16:57:05) dengan dimulainya sesi koneksi FTP ilegal yang terpantau pada jaringan.

2.3 Analisis Paket (Deep Packet Inspection)

Tim SOC mengekstrak file Packet Capture (pcap) dari sensor jaringan dan membukanya menggunakan Wireshark untuk melakukan pemeriksaan muatan data (payload inspection) secara forensik digital.



Dari hasil Deep Packet Inspection pada paket di atas, ditemukan bukti konkret kebocoran keamanan:

1. Kebocoran Kredensial: Protokol FTP mentransmisikan data otentikasi tanpa enkripsi (cleartext). Paket nomor 763 secara jelas menampilkan string identitas user USER kel9, dan paket nomor 765 menampilkan kata sandi dalam bentuk teks polos yaitu PASS kel9.
2. Aktivitas Eksfiltrasi Dokumen: Pada paket nomor 1832, tercatat instruksi perintah STOR data_korban.txt. Ini membuktikan penyerang tidak sekadar mengintip lalu lintas data, melainkan telah berhasil memanipulasi sesi untuk menyalin dokumen rahasia dari atau ke direktori server FTP.
3. Bukti Forensik Struktur Header: Pada pemeriksaan struktur ethernet paling bawah, tercatat informasi janggal:
 - Src IP: 192.168.9.50 (IP Server Asli)
 - Src MAC: 08:00:27:63:60:05 (Fisik Perangkat Kali Linux milik Attacker)
 - Dst MAC: 08:00:27:37:c3:a6 (Fisik Perangkat Korban/Victim) Ketidaksesuaian logis ini (di mana IP Server dikirim oleh alamat MAC milik Attacker) menjadi bukti absolut bagi tim SOC bahwa tabel ARP jaringan lokal dalam kondisi teracuni (poisoned).

2.4 Kategori Insiden

Berdasarkan parameter taksonomi insiden siber, kejadian ini diklasifikasikan ke dalam:

- Kategori Utama: Unauthorized Access / Confidentiality Breach (Akses Tidak Sah dan Kebocoran Kerahasiaan Data).
- Vektor Serangan: Impersonation / Spoofing at Link Layer (Penyamaran Identitas Perangkat Fisik).

- Tingkat Dampak Teknis: HIGH (Tinggi), karena penyerang berhasil mendapatkan kredensial administratif tingkat dasar dan memiliki kemampuan membaca serta memanipulasi file di dalam server FTP internal.

BAB III: FASE PENAHANAN & PEMULIHAN

(CONTAINMENT, ERADICATION, & RECOVERY)

3.1 Penahanan (Containment)

Setelah memvalidasi keaslian serangan pada fase analisis, tim SOC segera mengeksekusi strategi penahanan taktis guna menghentikan aktivitas penyadapan tanpa perlu mematikan seluruh server utama perusahaan (menjaga aspek availability bisnis). Langkah penahanan dijalankan di level Switch (VM-SWITCH) dengan memanfaatkan utilitas Ebttables (Ethernet Bridge Tables) untuk memfilter lalu lintas langsung berdasarkan MAC Address di Layer 2:

```
kel19@VM-SWITCH-KEL09F:~$ sudo ebttables -L FORWARD
Bridge table: filter

Bridge chain: FORWARD, entries: 3, policy: ACCEPT
-p ARP -i enp0s9 --arp-ip-src 192.168.9.50 -j DROP
-p ARP -i enp0s9 --arp-ip-src 192.168.9.1 -j DROP
-s ! 08:00:27:63:b0:05 -i enp0s9 -j DROP
kel19@VM-SWITCH-KEL09F:~$
```

Analisis Hasil Aturan: Aturan pertama memblokir semua paket keluar yang bersumber (source) dari perangkat penyerang, sehingga menghentikan injeksi paket ARP reply palsu ke jaringan. Aturan kedua memblokir semua lalu lintas yang ditujukan (destination) ke penyerang, secara instan memutus jalur pembelokan data (sniffing loop). Jalur komunikasi data dari Victim kembali dipaksa melewati rute normal jaringan tanpa bisa diintersepsi lagi oleh penyerang.

3.2 Pembersihan (Eradication)

Fase pembersihan fokus pada pembersihan sisa-sisa manipulasi serangan dari sistem internal:

1. Flushing ARP Cache: Tim SOC membersihkan tabel cache ARP yang terlanjur teracuni pada mesin Victim PC dan Web/FTP Server guna menghapus entri MAC address palsu milik penyerang.
2. Pemutusan Sesi FTP Ilegal: Mematikan paksa (kill session) seluruh koneksi aktif yang terikat dengan IP penyerang pada layanan FTP daemon server untuk memastikan tidak ada backdoor session yang tertinggal.

3.3 Pemulihan (Recovery)

Fase pemulihan memastikan sistem kembali beroperasi secara normal dengan tingkat keamanan yang ditingkatkan:

1. Uji Konektivitas Pasca-Insiden: Menguji kembali konektivitas dasar menggunakan perintah ping dari Victim ke Server guna memastikan jalur komunikasi L2 telah bersih dari pembelokan. Hasil pengujian menunjukkan konektivitas sukses 100% dengan latensi kembali normal (tidak ada delay akibat pembelokan rute).
2. Verifikasi Mitigasi Melalui Simulasi Ulang: Penyerang mencoba menjalankan kembali automated tools Hydra atau arpspoof dari mesin Kali Linux. Hasil pengujian menunjukkan status serangan GAGAL secara total (muncul pesan Connection Timed Out atau Destination Host Unreachable pada sisi penyerang). Hal ini membuktikan bahwa solusi penahanan Layer 2 menggunakan Ebtables bekerja secara valid dan presisi.

BAB IV: AKTIVITAS PASCA INSIDEN (POST-INCIDENT ACTIVITY)

4.1 Lessons Learned

Melalui simulasi SOC Analyst ini, tim kami mendapatkan beberapa pelajaran penting terkait tata kelola keamanan jaringan lokal:

1. Protokol Tanpa Otentikasi Adalah Titik Lemah Utama: Kepercayaan mutlak protokol ARP terhadap paket broadcast tanpa adanya validasi silang merupakan celah keamanan bawaan yang sangat fatal pada jaringan lokal.
2. Bahaya Nyata Protokol Plaintext: Penggunaan protokol warisan (legacy) seperti FTP port 21 terbukti mempermudah penyerang pemula sekalipun untuk mendapatkan data kredensial rahasia secara utuh hanya dengan teknik sniffing sederhana.
3. Pentingnya Visibilitas Deteksi Dini: Tanpa adanya konfigurasi SPAN Port yang dialirkan ke SIEM (Security Onion) dan deteksi aktif dari Arpwatch, aktivitas penyadapan MITM dapat berlangsung berbulan-bulan di jaringan perusahaan tanpa pernah disadari oleh tim IT internal perusahaan (zero visibility).

4.2 Rekomendasi Hardening

Guna mencegah terjadinya insiden serupa di masa mendatang, kami menyusun rekomendasi penguatan teknis jaringan (security hardening) sebagai berikut:

No	Komponen Keamanan	Kondisi Awal (Vulnerable)	Konfigurasi Hardening Rekomendasi
1	Mekanisme ARP Jaringan	Menggunakan ARP dinamis (Otomatis menerima semua broadcast reply).	Mengaktifkan Dynamic ARP Inspection (DAI) pada switch atau mengonfigurasi Static ARP Binding permanen pada host-host kritis.
2	Protokol Transmisi Data	Layanan FTP biasa pada Port 21 (Data mengalir secara plaintext).	Mematikan FTP biasa dan bermigrasi total ke SFTP (SSH File Transfer Protocol) port 22 atau mengaktifkan enkripsi TLS/SSL (FTPS).
3	Keamanan Port Switch	Port switch menerima MAC Address apa saja tanpa batas (Unrestricted).	Mengaktifkan fitur Port Security / Static FDB di level Switch dengan batasan Maximum MAC Address = 1 menggunakan skema Sticky MAC.
4	Manajemen Lalu Lintas	Protokol IPv6 aktif default tanpa pemantauan khusus.	Menonaktifkan total protokol IPv6 dan fitur SLAAC jika jaringan internal hanya

			berbasis IPv4 untuk memperkecil attack surface.
--	--	--	---